Ep 11 · AI Security & Governance — Cheat Sheet

AI System Design · AI Engineering with Ajit · github.com/byruajit/ai-system-design

PROMPTS ARE NOT SECURITY BOUNDARIES

Design for "the model **will** be tricked": limit the blast radius.

DEFENCE IN DEPTH (OUTSIDE → IN)

1. **Identity:** SSO, user-scoped retrieval & tools
2. **Input:** limits + injection screening (user **and** retrieved content)
3. **PII:** redact before send/log
4. **Model:** approved · pinned · regional · no-training terms
5. **Output:** PII filter · citation ACL check · encode/validate
6. **Agency:** allowlists · approvals · no money movement
7. **Audit:** immutable · hashes · versions · guardrail decisions
8. **Governance:** inventory · risk tiers · change approval · revalidation
9. **Red-team** suite in CI + periodic human exercises

OWASP LLM RISKS → CONTROLS

Injection → privilege + approvals · Disclosure → ACLs + redaction · Excessive agency → allowlists · Output handling → treat as untrusted · Supply chain → inventory + pinning · Unbounded consumption → budgets

AUDIT RECORD

request ID · user · time · chunks + versions · model/prompt/config version · guardrails fired · tool calls + approvals · redacted answer + hashes

INDIAN PII TO REDACT

PAN · Aadhaar · card (Luhn) · mobile · email · account no.

ACCOUNTABILITY (RACI)

Business owner: accountable · Model risk: validates · Security/privacy: approve data flows · Audit: assures